

main-report

HW06 API Testing Report — Member 4

1. Scope and sources

SUT: EShop backend, base URL `http://localhost:3000`, pinned upstream commit `85af3ba875c88283615e22cb108f13e2fccaf0e9`.

Selected features follow team allocation: FR-04, FR-10 and FR-19. API contract source: `api_specification.md`; behavioral oracle: SRS/README, especially FR-04, FR-10, FR-12, FR-19 and SEC-01–SEC-07.

2. Test strategy

Each feature receives at least 40 AI-assisted cases plus at least five cases added after human audit. Current draft contains 40/45/40 AI cases for FR-04/FR-10/FR-19 respectively (125 AI cases total) and 15 human-added cases. Coverage dimensions: equivalence partitions, boundaries, negative validation, state transitions, authentication/authorization, IDOR/mass assignment, sensitive-data exposure and response schema.

Status oracle used in automation: 2xx for valid operations; 400 for malformed/invalid business input; 401 for missing/invalid authentication; 403 for authenticated but unauthorized role; 404 for missing resource. Where source specification omits exact status/body, report records the assumption and checks invariant behavior rather than inventing a schema.

3. FR-04 coverage

GET `/api/users/me` checks authentication, identity binding, schema, forbidden sensitive fields and repeatability. PUT `/api/users/me` checks valid updates, phone partitions (10/11 digits beginning with 0), name/address boundaries, null/type handling, ignored email, rejected role mass assignment and cross-user isolation.

Expected invariants: only authenticated user can access own profile; email and role remain unchanged; password/reset token are never returned; only intended fields change.

4. FR-10 coverage

The transition matrix covers every source/destination pair among pending, confirmed, shipping, delivered and canceled. Valid paths are pending→confirmed→shipping→delivered, plus pending/confirmed→canceled. User cancellation is checked against ownership and state. Terminal states must reject every outgoing transition. Replay, backward transitions, unknown status and stale IDs are included.

5. FR-19 coverage

GET `/api/admin/users` checks admin-only access, token handling, list schema and password/reset-token absence. DELETE `/api/admin/users/:id` checks valid deletion, invalid IDs, repeated deletion, IDOR, regular-user access and self-delete prohibition. Deletion tests run last and database resets before each full execution.

6. Audit and extension

Every generated case is labelled VALID, INVALID or INCOMPLETE with a reason. Corrected cases retain their original AI text and a human revision. Human-added cases are accepted only when absent from the generated set and include a reason for the AI miss.

Detailed rows: `../test-cases/member-4.csv` and `../test-cases/member-4.xlsx`.

7. Execution

Collection: `../postman/HW06_member4_collection.json` contains 10 executable setup/smoke items plus 140 test-case-linked items. Environment: `../postman/HW06_member4_environment.json`. All requests use collection-level pre-request injection of `X-Student-Id: {{studentId}}`, configured as MSSV 23127326. Newman output belongs in `../newman/` after resolving fixture/oracle rows marked INCOMPLETE.

CI smoke gate with MSSV 23127326: 7 requests, 7 assertions, 7 passed. The local 10-item smoke report records 7 passed and 3 failed. Full collection run: 150 requests/assertions, 84 passed and 66 failed. The catalogue rows are reconciled to Newman item names and observed HTTP results in `../test-cases/member-4.csv`. Additional direct verification confirmed FR-04 sensitive-field exposure, yielding four confirmed defect observations total. Failure classification: 4 defect occurrences, 0 expected-negative, and 62 fixture issues; details are in `failure-classification.md`.

8. Agent Skill design

The reusable generator is documented in `../agent-skill/pseudocode.md` and `../agent-skill/skill-design.md`. The flow diagram is supplied as `../agent-skill/diagram.png`, with editable `diagram.svg` and Mermaid source `diagram.md`. The design deliberately places a human-oracle gate between AI drafting and execution.

9. Defects

Only reproducible observations are bugs. Static code observations are hypotheses, not findings. Candidate areas requiring final evidence: role mass assignment/profile data exposure; missing admin role enforcement; illegal order transitions; user cancellation during shipping; admin self-delete.

10. Evidence links and limitations

GitHub Issues #1–#4 and CI run links are recorded in `../bug-reports/member-4.md` and `cicd-report.md`; corresponding PNG evidence is in `../evidence/`. The student-recorded demo video is intentionally left as VIDEO_URL_PENDING in the submission README and must be replaced before Moodle upload.